

Security+ 5.6 · Security Awareness

Mestre CyberSec — PDF baseado na aula do Professor Messer · 5.6 — Security Awareness (6:45) · [vídeo original](#) · [YouTube](#)

Phishing campaigns (simula e mensura); reporting options (botão de 'reportar' fácil); user training (contínuo, não só anual); anomalous behavior recognition.

Highlights que a prova cobra

- Simulated phishing: o melhor treino — clica e aprende
- Reporting fácil = taxa de reporte real (a métrica que importa)

Dicas de prova

- 'simulated phishing email sent to measure employee awareness'=phishing campaign

Cenário clássico: 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing campaign.

Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Golpista liga se passando por suporte de TI e cria urgência pra tu dar a senha. O princípio de engenharia social explorado é:

- A)** Escassez
- B)** Autoridade + urgência
- C)** Prova social
- D)** Reciprocidade

2. Um funcionário recebe ligação de alguém se passando por suporte técnico solicitando senha para 'atualização do sistema'. Que técnica é essa?

- A)** Vishing
- B)** Pretexting
- C)** Baiting
- D)** Tailgating

3. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Simulated phishing: o melhor treino — clica e aprende'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Simulated phishing: o melhor treino — clica e aprende...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Reporting fácil = taxa de reporte real (a métrica que importa)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Reporting fácil = taxa de reporte real (a métrica que importa)...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'simulated phishing email sent to measure employee awareness'=phishing campaign'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'simulated phishing email sent to measure employee awareness'=phishing camp...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing campaign.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Simulated phishing: o melhor treino — clica e aprende'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Simulated phishing: o melhor treino — clica e aprende...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: 'Reporting fácil = taxa de reporte real (a métrica que importa)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Reporting fácil = taxa de reporte real (a métrica que importa)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

9. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: "simulated phishing email sent to measure employee awareness'=phishing campaign'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'simulated phishing email sent to measure employee awareness'=phishing camp...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Security Awareness): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 5.6), um analista avalia o seguinte requisito técnico: "empresa manda email de phishing simulado e mede quantos clicaram'=phishing campaign.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing...

GABARITO COMENTADO

- 1) B — Autoridade + urgência.** Fingir autoridade (TI) + pressa desliga o pensamento crítico. É o combo clássico da engenharia social — teu lado investigador reconhece o roteiro.
- 2) A — Vishing.** Vishing = phishing por VOZ/telefone (a 'ligação' é a chave). O golpista finge ser o suporte pra extrair a senha. (Pretexting é a técnica do cenário inventado, muitas vezes usada JUNTO com o vishing.)
- 3) C — Implementar a solução correspondente: Simulated phishing: o melhor treino — clic.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): Simulated phishing: o melhor treino — clica e aprende. As demais alternativas configuram violações graves de confô
- 4) B — Implementar a solução correspondente: Reporting fácil = taxa de reporte real (a**
. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): Reporting fácil = taxa de reporte real (a métrica que importa). As demais alternativas configuram violações graves
- 5) A — Implementar a solução correspondente: 'simulated phishing email sent to measure**
. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): 'simulated phishing email sent to measure employee awareness'=phishing campaign. As demais alternativas configuram
- 6) B — Implementar a solução correspondente: 'empresa manda email de phishing simulado**
. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing campaign.. As demais alternativas conf
- 7) B — Implementar a solução correspondente: Simulated phishing: o melhor treino — clic.** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): Simulated phishing: o melhor treino — clica e aprende. As demais alternativas configuram violações graves de confô
- 8) A — Implementar a solução correspondente: Reporting fácil = taxa de reporte real (a**
. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): Reporting fácil = taxa de reporte real (a métrica que importa). As demais alternativas configuram violações graves
- 9) A — Implementar a solução correspondente: 'simulated phishing email sent to measure**
. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): 'simulated phishing email sent to measure employee awareness'=phishing campaign. As demais alternativas configuram
- 10) D — Implementar a solução correspondente: 'empresa manda email de phishing simulado**
. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 5.6 (Security Awareness): 'empresa manda email de phishing simulado e mede quantos clicaram'=phishing campaign.. As demais alternativas conf

